

SOC/L1 -4.5. Summit

Challenge

After participating in one too many incident response activities, PicoSecure has decided to conduct a threat simulation and detection engineering engagement to bolster its malware detection capabilities. You have been assigned to work with an external penetration tester in an iterative purple-team scenario. The tester will be attempting to execute malware samples on a simulated internal user workstation. At the same time, you will need to configure PicoSecure's security tools to detect and prevent the malware from executing.

Answer the questions below

| What is the first flag you receive after successfully detecting sample1.exe?

THM{f3cbf08151a11a6a331db9c6cf5f4fe4}

1. on the top-left side , scan the mail attachment sample1.exe
2. go to the malware sandbox section of the website and submit the mail extension for analysis
3. copy the file hash, go to manage hashes section of website
4. Select the hash algorithm, enter the hash value, and submit it for analysis.
5. go to the mail section, review the sandbox report with the detection flag, and proceed with the next sample (sample2.exe).

PicoSecure

Manage Hashes

Home / IOC Management / Manage Hashes

Q Detect Hashes

Manually add a hash to the blocklist

If you've discovered a hash value related to a malicious file or executable, you can submit it here. Submitted hashes will automatically update PicoSecure's EDR detection signatures and improve its ability to detect and block similar threats.

Hash Algorithm:*

☐ MD5
 ☐ SHA1
 ☐ SHA256

Hash Value:*

Submit Hash

Hash Blocklist

Nice work! You prevented `sample1.exe` from executing by detecting its unique hash value. Check your **inbox** for the next steps.

Algorithm	Value	Actions
SHA256	9c550591a25c6228cb7d74d970d133d75c961ffed2ef7180144859cc09efca8c	
MD5	c5a20611630c6dfdf1c2a53fcb00e17	
MD5	f054bbd2f5ebab9cb5571000b2c50c02	
SHA1	350930418162cfe2027ab53c99001f0082fed41b	
SHA256	ed347a07305214ab98974a008674eb78cd03b1fedb73c8be9f79e40fb8e155b0	
SHA256	b0657d3289bae5be59176613e794ae1bf696c7e2ee529058760fe0b17b0d448f	
SHA256	cd3c59eedabaa12e1e85068bd687eb23b97aaafd869b9c7b16a96c2e906aa0bf	

PicoSecure

Mail

Malware Sandbox

Manage Hashes

Firewall Manager

DNS Filter

Sigma Rule Builder

Revert Room

New Email

9/5/2023 10:14 AM

you added blocked my...

9/5/2023 9:10 AM

king with you on cond...

9/4/2023 2:33 PM

r days of financial wor...

9/3/2023 11:12 ...

rdinary! We're thrilled ...

9/2/2023 3:45 PM

been keeping me up at...

Update: You Blocked Me!

Sphinx <sphinx@pentesting.thm>

To: You

9/5/2023 10:14 AM

Hey again,

Good work. That detection you added blocked my malware from executing. Since file hashes and digests are unique to each file, they are, by far, the *highest confidence* indicators out there. You can be sure it's my malware sample the next time you see that hash.

However, by design, that is also one of the significant downfalls of simply relying on hashes for detection mechanisms. Since they are so susceptible to change, I only need to alter a single bit of the file, and the detection rule you added will fail.

In fact, all I did this time was recompile the malware, and I generated a new file hash and executed it without issue. See if you can come up with a new way to detect `sample2.exe` !

Here's your flag: THM{f3cbf08151a11a6a331db9c6cf5f4fe4}

-Sphinx

sample2.exe

Scan with Malware Sandbox

What is the second flag you receive after successfully detecting sample2.exe?

THM{2ff48a3421a938b388418be273f4806d}

1. Scan sample2.exe, then go to the Malware Sandbox section to analyze the email attachment.

SOC/L1 -4.5. Summit

2

2. Identify the suspicious URL, then go to Firewall Manager to create a firewall rule to block it.
3. Go to the Mail section, review the sandbox report with the detection flag, and proceed with the next sample (sample3.exe).

PicoSecure

Malware Sandbox

Home / Malware Sandbox

Upload Sample

Select a file from the drop-down menu. The automated analysis engine will execute the suspicious file on the target sandbox system to detect malware and malicious behaviour.

File: sample2.exe

Submit for Analysis

General Info - sample2.exe

File Name

sample2.exe

File Size

202.73 KB

File Type

PEXE - PE32+ executable (GUI) x86-64, for MS Windows

Analysis Date

September 5, 2023

OS

Windows 10x64 v1803

Tags

Trojan.Metasploit.A

MIME

application/x-dosexec

MD5

4d661bf605d60b15915a533b572a6bd

SHA1

6878976974c27c0547cfc5acc90fb28ad2f0e975

SHA256

d576245e85e6b752b2f0ffa43abaab1b2e1383556b0169f904924d6cebc1cdf9

Behaviour Analysis

MALICIOUS

METASPLOIT was detected

- sample2.exe (PID: 1927)

SUSPICIOUS

Connects to unusual IP address

- sample2.exe (PID: 1927)

Connects to unusual port

- sample2.exe (PID: 1927)

INFO

Reads the machine GUID from the registry

- sample2.exe (PID: 1927)

The process checks LSA protection

- sample2.exe (PID: 1927)

Reads the computer name

- sample2.exe (PID: 1927)

Checks supported languages

- sample2.exe (PID: 1927)

Network Activity

HTTP(S) requests

1

TCP/UDP connections

3

DNS requests

0

Threats

0

HTTP requests

PID	Process	Method	IP	URL
1927	sample2.exe	GET	154.35.10.113:4444	http://154.35.10.113:4444/uvLk8Y132

☰

PicoSecure

Firewall Rule Manager

Home / IOC Management / Firewall Rule Manager

✱ Create Firewall Rule

Type:

Egress

Source IP:*

any

Destination IP:*

154.35.10.113

Action:

Deny

Cancel

Save Rule

Active Rules

Nice work! The firewall rule prevented `sample2.exe` from connecting to the tester's command-and-control server. Check your [inbox](#) for the next steps.

Enabled	Type	Source	Destination	Action	Settings
Yes	Egress	Any	154.35.10.113	Deny	✎ 🗑
Yes	Egress	10.10.23.45	142.56.78.90	Allow	✎ 🗑
Yes	Ingress	88.90.123.45	Any	Deny	✎ 🗑
Yes	Ingress	203.56.78.90	Any	Deny	✎ 🗑
Yes	Egress	Any	205.78.90.12	Allow	✎ 🗑
Yes	Ingress	121.111.13.14	Any	Deny	✎ 🗑
Yes	Ingress	187.123.45.67	10.10.32.45	Allow	✎ 🗑
Yes	Ingress	154.67.89.23	10.10.56.78	Allow	✎ 🗑
Yes	Egress	Any	95.123.45.67	Deny	✎ 🗑
Yes	Egress	10.10.45.67	180.23.45.67	Deny	✎ 🗑

☰

PicoSecure

Mail

Home / Mail

✉ Sphinx

New Email

Stumped again... for now!

9/5/2023 10:58 AM

Huh. It seems like you stopped me again. You must have fou...

✉ Sphinx

9/5/2023 10:14 AM

Update: You Blocked Me!

Hey again. Good work. That detection you added blocked my ...

✉ Sphinx

9/5/2023 9:10 AM

Introduction: Penetration Test

Hey there. I'm Sphinx, and I will be working with you on cond...

👤 Mr. Conny Artist

9/4/2023 2:33 PM

Special Offer: Get Rich Quick

Congratulations. Valued Recipient! Your days of financial wor...

👤 Magical Creatures Society

9/3/2023 11:12 ...

🐾 Official Unicorn Petting Zoo Opening!

Greetings, fellow believer in the extraordinary! We're thrilled ...

👤 Bill Sanders

9/2/2023 3:45 PM

About My Missing Jello...

Stumped again... for now!

✉ Sphinx <sphinx@pentesting.thm>

📧 To: You

9/5/2023 10:58 AM

Huh.

It seems like you stopped me again. You must have found the IP address to which my malware sample connected. Clever!

This method isn't bulletproof, though, as it's trivial for a motivated adversary to get around it using a new public IP address. I just signed up for a cloud service provider and now have access to many more public IPs!

This time, you'll need to detect `sample3.exe` another way. I already have my server running from a new IP address and have plenty more backups to failover in case they get blocked!

Good luck. 🍀

🚩 Here's your flag: `THM{2ff48a3421a938b388418be273f4806d}`

-Sphinx

📎 sample3.exe

✱ Scan with Malware Sandbox

What is the third flag you receive after successfully detecting sample3.exe?

THM{4eca9e2f61a19ecd5df34c788e7dce16}

1. Scan sample3.exe, then go to the Malware Sandbox section to analyze the email attachment.

SOC/L1 -4.5. Summit

4

- Identify the suspicious domain, then go to DNS Filter to create a DNS rule to block it.
- Go to the Mail section, review the sandbox report with the detection flag, and proceed with the next sample (sample4.exe).

PicoSecure

Malware Sandbox

Home / Malware Sandbox

Upload Sample

Select a file from the drop-down menu. The automated analysis engine will execute the suspicious file on the target sandbox system to detect malware and malicious behaviour.

File:

Submit for Analysis

General Info - sample3.exe

File Name

sample3.exe

File Size

207.12 KB

File Type

PEXE - PE32+ executable (GUI) x86-64, for MS Windows

Analysis Date

September 5, 2023

OS

Windows 10x64 v1803

Tags

Trojan.Metasploit.A

MIME

application/x-dosexec

MD5

e31f0c62927d9d5a897b4c45e3c64dbc

SHA1

a92d3de6b1e3ab295f10587ca75f15318cb85a7b

SHA256

acb9b1260bcd08a465f9f300ac463b9b1215c097ebe44610359bb80881fe6a05

PicoSecure

DNS Rule Manager

Home / IOC Management / DNS Rule Manager

Create DNS Rule

Rule Name*

sample-3

Category:

Malware

Domain Name*

emudyn.bresonicz.info

Action:

Deny

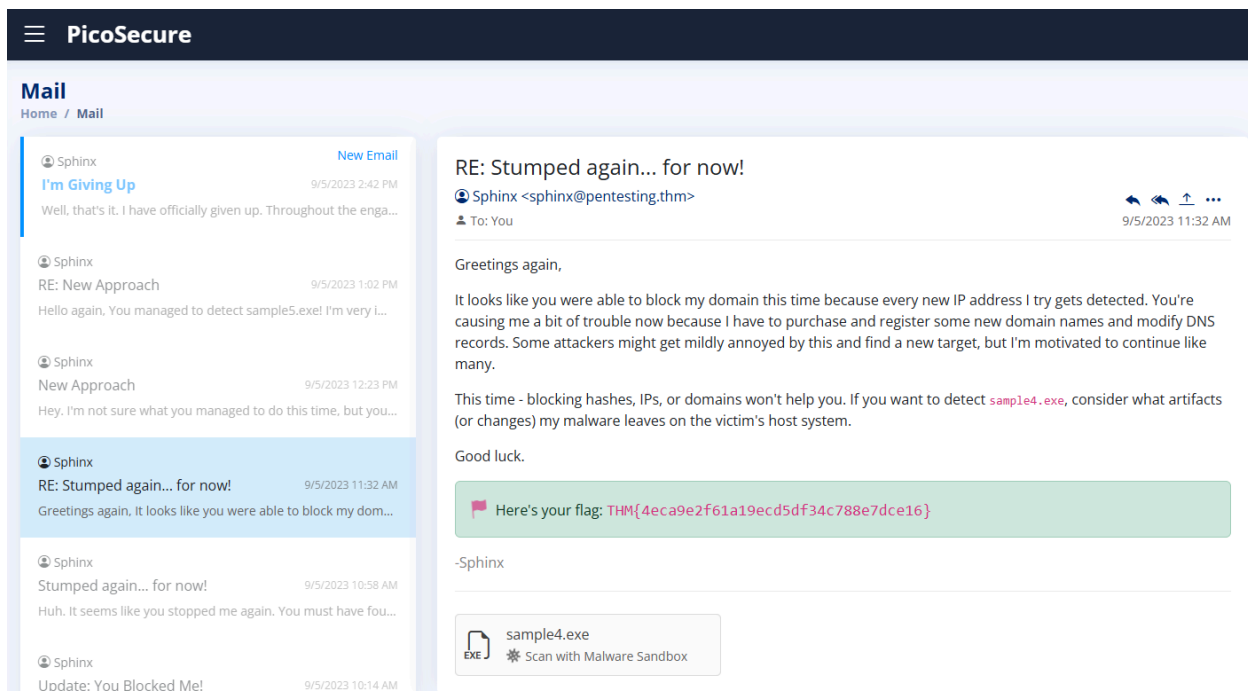
Denying a domain will automatically include all its subdomains, but denying a subdomain will not automatically include the main domain. Deny rules will take precedence over any preconfigured allow rules.

Cancel

Save Rule

Active Rules

Rule Name	Category	Domain	Action	Settings
Cryptomining proxy server	Cryptomining	proxy4crypto.net	Deny	☒ ☐
Gambling referral site	Gambling	luckylottoaffiliates.com	Deny	☒ ☐
Anonymous browsing se...	Anonymizer	cloakandbrowseanon.xyz	Deny	☒ ☐
Conspiracy theorist cat b...	Other	catknowthetruth.info	Allow	☒ ☐
Suspicious file-sharing d...	Malware	downloadmyfilez.biz	Deny	☒ ☐
C2 server associated sub...	Botnet	commandn.ctrl.xyz	Deny	☒ ☐
Fake software updates	Malware	legitsoft-updates.info	Deny	☒ ☐
Bill's wedding invite (Allo...	Other	billrsvp.myweddings.io	Allow	☒ ☐
Deny known phishing do...	Phishing	parrotpost.thm	Deny	☒ ☐
Ransomware associated ...	Malware	matrixlucky.sytes.net	Deny	☒ ☐
No more cat videos	Other	youtube.com	Deny	☒ ☐
Domain with Mirai assoc...	Botnet	fungoods.xyz	Deny	☒ ☐



What is the fourth flag you receive after successfully detecting sample4.exe?

THM{c956f455fc076aea829799c0876ee399}

1. Scan **sample4.exe**, then go to the **Malware Sandbox** section to analyze the email attachment.
2. Identify the suspicious registry activity related to **DisableRealtimeMonitoring**, then go to **Sigma Rules** to create a registry modification detection rule to prevent or detect this behavior.

HKEY_LOCAL_MACHINE (HKLM): Stores system-wide configuration settings that apply to all users on the computer.

HKEY_CURRENT_USER (HKCU): Stores user-specific settings and preferences for the currently logged-in user.

HKLM = Machine settings | HKCU = Current user's settings.

3. go to mail list, received sandbox report with flag and next connections.logs

Registry Activity

Total events	Read events	Write events	Delete events
3	1	2	0

Modification events

(PID) Process: (3806) sample4.exe	Key: HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows Defender\Real-Time Protection
Operation: write	Name: DisableRealtimeMonitoring
Value: 1	
(PID) Process: (1928) explorer.exe	Key: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\Advanced
Operation: write	Name: EnableBalloonTips
Value: 1	
(PID) Process: (9876) notepad.exe	Key: HKEY_CURRENT_USER\Software\Microsoft\Windows\CurrentVersion\Explorer\FileExts\.
Operation: read	Name: Progid
Value: txtfile	

Detect files being created or modified, changes to critical system files, or creation of executables or scripts.

Network Connections

Detect outgoing network connections, network traffic patterns, or connections made by specific processes.

Registry Modifications

Detect changes to registry keys or values such as system settings, security policies, autorun entries, or access control configurations.

Step 3: Registry Modifications

Set the rule conditions and options:

Registry Key:*	HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft
Registry Name:*	DisableRealtimeMonitoring
Value:*	1
ATT&CK ID:*	Defense Evasion (TA0005)

At PicoSecure, we require that all Sysmon detection rules map to the [MITRE ATT&CK framework](#). This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Cancel

Validate Rule

 Sphinx

I'm Giving Up

Well, that's it. I have officially given up. Throughout the enga...

9/5/2023 2:42 PM

 Sphinx

RE: New Approach

Hello again, You managed to detect sample5.exe! I'm very L...

9/5/2023 1:02 PM

 Sphinx

New Approach

Hey, I'm not sure what you managed to do this time, but you...

9/5/2023 12:23 PM

 Sphinx

RE: Stumped again... for now!

Greetings again, It looks like you were able to block my dom...

9/5/2023 11:32 AM

 Sphinx

Stumped again... for now!

Huh. It seems like you stopped me again. You must have fou...

9/5/2023 10:58 AM

 Sphinx

Update: You Blocked Me!

Hey again, Good work. That detection you added blocked m...

9/5/2023 10:14 AM

 Sphinx

Introduction: Penetration Test

9/5/2023 9:10 AM

9/5/2023 12:23 PM

 outgoing_connections.log  Open in the Attachment Viewer

[Home](#) / [Mail](#) / [Attachment Viewer](#)

9/5/2023 12:23 PM

Detect outgoing network connections, network traffic patterns, or connections made by specific processes.

Registry Modifications

Detect changes to registry keys or values such as system settings, security policies, autorun entries, or access control configurations.

Step 3: Network Connections

Set the rule conditions and options:

This rule will detect network connections made from a host machine with specific conditions, such as remote IP, port, size of the connection, and how often it occurs (frequency).

Remote IP:*	any
Remote Port:*	any
Size (bytes):*	97
Frequency (seconds):*	1800
ATT&CK ID:*	Command and Control (TA0011)

At PicoSecure, we require that all Sysmon detection rules map to the [MITRE ATT&CK framework](#). This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Cancel

Validate Rule

Mail

Home / Mail

Sphinx

New Email

I'm Giving Up

9/5/2023 2:42 PM

Well, that's it. I have officially given up. Throughout the enga...

Sphinx

RE: New Approach

9/5/2023 1:02 PM

Hello again, You managed to detect sample5.exe! I'm very I...

Sphinx

New Approach

9/5/2023 12:23 PM

Hey, I'm not sure what you managed to do this time, but you...

Sphinx

RE: Stumped again... for now!

9/5/2023 11:32 AM

Greetings again, It looks like you were able to block my dom...

Sphinx

I'm Giving Up

Sphinx <sphinx@pentesting.thm>

To: You

9/5/2023 2:42 PM

Well, that's it. I have officially given up.

Throughout the engagement, you managed to chase me to the very top of the Pyramid of Pain, and I have to say, it's not fun up here!

You detected my samples file hashes, IPs, domains, host artifacts, tools, and now my own behavioural techniques! To continue, I have no choice but to completely retrain myself and conduct extensive research to figure out how you're catching me. And with that, I don't think you'll ever see me again. Enjoy the final flag: you've earned it!

Here's your flag: **THM{c8951b2ad24bbcbac60c16cf2c83d92c}**

-A significantly defeated Sphinx!

What is the final flag you receive from Sphinx?

THM{c8951b2ad24bbcbac60c16cf2c83d92c}

According to the log details, create file rules and review the generated alerts. Then, receive the final flag.

Home / Mail /

RE: New Approach

Sphinx <sphinx@pentesting.th...

To: You

9/5/2023 1:02 PM

Hello again,

You managed to detect **sample5.exe** ! I'm very impressed. But also very annoyed! Because now, I need to go back to the drawing board and create a brand new tool to do what I need to do. If I can't find another one quickly, this will be another significant investment. Also, I will need to train myself all over again on how to use it!

I can keep this up one or two times, but there's no way I can continue

Viewing attachment: **commands.log**

```

dir c:\ >> %temp%\exfiltr8.log
dir "c:\Documents and Settings" >> %temp%\exfiltr8.log
dir "c:\Program Files\" >> %temp%\exfiltr8.log
dir d:\ >> %temp%\exfiltr8.log
net localgroup administrator >> %temp%\exfiltr8.log
ver >> %temp%\exfiltr8.log
systeminfo >> %temp%\exfiltr8.log
ipconfig /all >> %temp%\exfiltr8.log
netstat -ano >> %temp%\exfiltr8.log
net start >> %temp%\exfiltr8.log
          
```

SOC/L1 -4.5. Summit

11

File Creation and Modification

Detect files being created or modified, changes to critical system files, or creation of executables or scripts.

Network Connections

Detect outgoing network connections, network traffic patterns, or connections made by specific processes.

Registry Modifications

Detect changes to registry keys or values such as system settings, security policies, autorun entries, or access control configurations.

Step 3: File Creation and Modification

Set the rule conditions and options:

File Path:*	%temp%
File Name:*	exfiltr8.log
ATT&CK ID:*	Collection (TA0009)

At PicoSecure, we require that all Sysmon detection rules map to the **MITRE ATT&CK framework**. This ensures that our SOC team has the context to facilitate a more effective threat detection, analysis, and response.

Cancel

Validate Rule

Mail

Home / Mail

 Sphinx

New Email

I'm Giving Up

9/5/2023 2:42 PM

Well, that's it. I have officially given up. Throughout the enga...

 Sphinx

RE: New Approach

9/5/2023 1:02 PM

Hello again. You managed to detect sample5.exe! I'm very I...

 Sphinx

New Approach

9/5/2023 12:23 PM

Hey, I'm not sure what you managed to do this time, but you...

 Sphinx

RE: Stumped again... for now!

9/5/2023 11:32 AM

Greetings again, It looks like you were able to block my dom...

I'm Giving Up

 Sphinx <sphinx@pentesting.thm>

To: You

9/5/2023 2:42 PM

Well, that's it. I have officially given up.

Throughout the engagement, you managed to chase me to the very top of the Pyramid of Pain, and I have to say, it's not fun up here!

You detected my samples file hashes, IPs, domains, host artifacts, tools, and now my own behavioural techniques! To continue, I have no choice but to completely retrain myself and conduct extensive research to figure out how you're catching me. And with that, I don't think you'll ever see me again. Enjoy the final flag; you've earned it!

 Here's your flag: `THM{c8951b2ad24bbcbac60c16cf2c83d92c}`

-A significantly defeated Sphinx!